Extra Exercises 21 – Running agents safely

To the cheatsheet: `01_cheatsheets/21_agent_safety`

Levels: ★ Getting started · ★★ Everyday · ★★★ Challenge **Rule:** Use only invented or anonymized data. All exercises work with any AI service and in the free plan. Suggested solutions are at the end. Only look after you're done.

Exercise 1 ★ – Applying the checklist

Scenario: A fictional calendar agent is supposed to suggest and enter appointments.

Task: For this agent, answer the five checklist points of "Before first use": permissions, limits, approvals, backup, kill switch. One to two sentences per point.

Hint: Remember the principle: read before write, as little as possible.

Exercise 2 ★ – Finding minimal permissions

Scenario: A file agent is supposed to sort PDFs in a folder.

Task: Which of these permissions does it really need (Y/N) and why? - a) Read all PDFs in the target folder - b) Write in the same folder (move/rename) - c) Full access to all folders on the hard drive - d) Internet access - e) Access to your emails

Hint: Every additional permission is an attack surface (topic 12). For each one ask: what breaks if the agent misuses it?

Exercise 3 ★★ – The failure case

Scenario: A fictional email agent has accidentally sent an unfinished reply to 30 recipients (invented situation).

Task: Walk through your emergency plan: what do you do in the first five minutes? What afterwards? Name concrete steps: recall the email (if possible), send a correction email, find the cause, adjust permissions, check the log.

Hint: The plan must exist before the incident – write it the way you would pull it up under stress.

Exercise 4 ★★ – Building a test environment

Scenario: You want to try out a file-sorting agent but only have real files.

Task: Plan a test environment: (1) How do you create a safe test environment with invented files (e.g. empty test folders with dummy files)? (2) Which three tests do you run first? (3) When would you let the agent loose on real files – and with what restrictions?

Hint: The test environment simulates the real thing, but without real damage. A test account instead of your real account is part of that.

Exercise 5 ★★★ – Safety plan for your own project

Scenario: You have a real (or fictional) agent use case from your everyday life.

Task: Create the complete safety plan: (1) The "Before first use" checklist, filled out. (2) Emergency plan (like Exercise 3). (3) Review plan: what do you check after the first, fifth, and twentieth run? (4) Abort criterion: when do you switch the agent off?

Hint: Abort criteria are often forgotten: define in advance which behavior is unacceptable (e.g. a single unconfirmed action with consequences is enough to stop).

Transfer (optional)

What is your personally most important safety point when using agents – and why? Write it down and pin it somewhere visible in your notes.

Suggested solutions

Exercise 1: Example: **Permissions** – read the calendar (all appointments), create appointments only as drafts/suggestions, no deleting. **Limits** – max. 10 suggestions per run, only for the coming week, max. 5 minutes runtime. **Approvals** – the human confirms every entry and every invitation. **Backup** – export the calendar before the first run; appointment changes must be reversible. **Kill switch** – disconnect, stop the agent, revoke access in the account settings.

Exercise 2: a) Yes – the core of the task. b) Yes, if sorting is the goal – but limited to exactly this folder. c) No – full access to everything is never necessary and is the maximum attack surface. d) No – sorting PDFs needs no internet; internet access opens injection paths. e) No – has nothing to do with the task.

Exercise 3: Example plan: **First 5 minutes:** stop further emails from being sent (pause/stop the agent), check whether more than one email is affected, if necessary don't alarm recipients before you have the facts. **Afterwards:** send a recall or correction email (short, factual, correct document), check the log (what exactly did the agent do? when?), find the cause (e.g. excessive permissions, missing approval), adjust permissions, run a test in the test environment, and only then reactivate.

Exercise 4: (1) Create a new empty "Test" folder with 5–10 invented PDF files (dummy names); restrict the agent to this folder only, ideally with a test account. (2) First tests: (a) normal case – does the agent sort correctly? (b) special case – what happens with an atypical file? (c) error case – behavior with duplicate names or a read-only file. (3) Real files only once all tests run cleanly – then initially with copies instead of originals, minimal permissions, and approvals before every change.

Exercise 5: Individual solution. Good answers include: the filled-out checklist (permissions, limits, approvals, backup, kill switch), a step-by-step emergency plan with

concrete locations (where do I revoke, where do I stop), a review plan (1st run: observe completely; 5th run: spot check; 20th run: check the log weekly), and clear abort criteria such as “a single unconfirmed action with consequences = immediate stop + permission review”.

Next: Cheatsheet 22 (Legal & compliance), Test E (`03_tests/test_E_agentic_systems`)

As of: October 2026